Cyber: Security Target and Protection Profile (ST/PP)

BGIN Block 15 · Georgetown University Capitol Campus, 111 Massachusetts Avenue NW, Washington, D.C.

Date	16 October 2026
Room	Room B (2416)
Published time	16:10–17:40
Workstream	st-pp
Status	Draft for working-group review. Source: closed captions.
Rule	Chatham House Rule. Information may be used without revealing the identity or affiliation of speakers or other participants, directly or indirectly.

This is a session record, not a transcript. Substantive discussion is retained with uncertainty and disagreement made explicit. Reported claims are not verified findings. Candidate agreements require working-group confirmation before use as decisions. Actions omit personal owners and identifying roles.

Agreements

The following sentences stand on their own. These are candidate agreements and reported points of convergence for working-group review. Inclusion does not establish consensus, verify a technical claim, or record formal adoption. The working group must confirm each decision before it is cited as such. Claims that were only discussed, including figures and alternatives that were not adopted, remain in full under Discussion.

A secure element, a secure chip, or an open-source component does not make a wallet secure. Evaluation has to cover how those parts are used, including paths the current certificates ignored.

Public failures are enough to justify the work: weak generators, seed exposure, and a hardware supply-chain tap on the display path. The certification that existed did not include the interface that failed. Scope was too narrow.

Do not start from zero. Common Criteria practice for smart cards, FIDO for authentication, GlobalPlatform TEE profiles, FIPS 140-3, PCI-driven HSM practice, eIDAS qualified signature-creation profiles, and the CSPN security targets are the baseline. Prefer an add-on to a certification vendors already pay for.

Functions already visible in the public hardware-wallet security targets are the right kind of content: stated entropy, attestation of the secure chip, user verification, secure update, application isolation across chains and across third-party applications.

Functions those targets missed and that this work has to add include seed-phrase confirmation, the chip-to-display path, hardware as well as firmware supply chain, and blind-signing protection. For HSM-backed signing, client-side consent must be bound to the bytes the back end signs, with proof of that binding back to the client.

MPC and threshold wallets are a different threat model from a single HSM, because collusion and inter-node confidentiality appear. They belong in their own profile if three profiles are written.

Post-quantum agility and the ability to migrate algorithms belong in the profile from the start.

Threats on the brainstorm list are a usable baseline. Security requirements are the next layer, at least one control per threat. A reference design is how the mapping gets tested and how developers get guidance without a single mandated implementation.

Vendors, users, and the agencies that certify have to be in the conversation. A short position paper is a reasonable way to get HSM and wallet vendors into a later meeting.

Small wallet teams will not reliably apply a decade of smart-card lessons unless the lessons are in an evaluation they must pass. Publishing CVEs has not been sufficient. CWE-1300 is a relevant side-channel identifier. The 2019 Trezor case and the recent display-path attack are the same lesson.

European identity-wallet certification and this work should share the overlapping requirements. They should not be forced into one scheme now.

The activity is close to a first draft and is not in draft. The blocker is the choice of first use case, which depends on who contributes.

The session's purpose is a process that can be shown to have been followed, so that a trivially weak product is harder to ship. It is not a claim that a profile prevents every future attack.

Documents considered

The session referred to the following documents, repositories, and standards. Bibliographic identifications and factual checks added during review are marked as editorial clarifications; they do not imply that the links were spoken or that the meeting adopted the findings. Names of the people who introduced the material are omitted.

Geneva GDC session, early September, on wallet assurance and the overlap with digital-identity wallets. Report on the BGIN website. No URL spoken. Slides for this block were largely that material.

Ledger CSPN security targets, first certification in 2019, later devices partially covered. Public because certification disclosure requires the security target. Functions and the display-path gap are as discussed above.

CSPN as a lightweight, fixed-duration evaluation, French in origin, described as aligned with a European lightweight scheme. ANSSI was the agency on the security target (captions: "SSI").

Common Criteria, as the smart-card and secure-element reference.

FIDO Alliance authenticator requirements, FIDO2 and UAF.

GlobalPlatform TEE protection profiles.

FIPS 140-3 and PCI-driven HSM practice.

eIDAS qualified signature-creation device protection profiles.

EU Cyber Resilience Act, cited via MITRE's PLC / open-PLC work that references CWE. Not a

wallet scheme.

ENISA certification schemes for digital-identity wallets, described as starting. Captions: "Anissa.".

CWE hardware class, CWE-1300 for side channels. A 2019 Trezor CVE, number not spoken.

MIT Digital Currency Initiative, OpenCBDC, open-wallet implementation, cited for exposure of the balance.

Coldcard weak-RNG firmware, and the Slope wallet seed exposure on Solana, as prior public failures.

The recent hardware supply-chain modification of retail hardware wallets, including the display-wire tap and the added component described as a SIM card. The related submitted supply-chain deck identifies the reseller as CryptoBilis. A German reseller was also mentioned, unnamed here.

Card Brand Mixup Attack: Bypassing the PIN in non-Visa Cards by Using Them for Visa Transactions (USENIX Security 2021): https://www.usenix.org/conference/usenixsecurity21/presentation/basin Bibliographic identification added editorially.

An Ethereum layer-2 interface-confusion case, remembered and not cited to a paper.

CPSA, Cryptographic Protocol Shapes Analyzer, MITRE. Mentioned after the close. TLA+ was the analogy for industry use of a formal model. No URL spoken.

IEEE and Trust over IP documents from the privacy session were referenced only as a pointer on credential portability. They are not security-target drafts.

Discussion

The following is the substance of the session. It preserves claims, figures, alternatives, and objections. Discussion does not establish a decision. Any candidate agreement requires explicit working-group confirmation.

Security targets and protection profiles for digital-asset wallets. Last session of the day. No written contributions had been received. Outreach to HSM vendors was described as underway and unsuccessful for this week, including Thales. GlobalPlatform contacts exist. Integrators and custodian-software providers are the audience a short statement might still attract. An attempt to bring hardware-wallet implementers, including Ledger, had not succeeded yet. The session was a working presentation, mostly of material prepared for the Geneva GDC meeting in early September, plus discussion. The intent was interactive. A close was announced. A short technical exchange on protocol-analysis tools continued in the room after that close; it is included below and was not part of the session's conclusions.

Why this is a BGIN work item. Wallet losses are not only misuse by holders. Threats have not been defined, and the controls that supposedly cover them have not been evaluated. The need, as stated by BGIN contributors and a few other stakeholders, is a security-evaluation process for wallets. Whether the first target is an institutional custodian, an end-user wallet, or both is open. Digital-asset wallets have specificities that ordinary key-management evaluations miss.

The Geneva session was chosen because digital-identity wallet assurance is already under discussion. Functions differ. One shared fact is that some wallets run on general-purpose devices, so any assumption

about the device or the platform has to be written down, along with what must be added. The Geneva room included people who evaluate security products and who were there for identity wallets. Attendance and questions were described as good. A report of that session is on the BGIN website. No URL was spoken. The session had been co-organized with other stakeholders and was described as mostly led by BGIN.

Failures already public. Badly implemented wallets, and misuse of security functions, are both in the set. The Coldcard random-number failure was current at the time of the Geneva presentation and was not the only case. Lack of entropy and misuse of generators recur. A Solana wallet incident about four years ago, the Slope wallet, was cited: the seed was not held securely and the private key was exposed. The captions say "slope of Solana Wallet Bridge."

What is repeatedly done wrong, in a standalone wallet or in a custodian component:

Weak random-number generation.

No security attestation of the components the wallet depends on.

Insecure key storage.

No isolation between processes. A key that is safe while at rest in a secure environment is exposed if the signature is computed in a rich operating system. That is the same class of mistake as leaving a trusted environment for a general-purpose OS.

A baseline of requirements for a target of evaluation already exists in other industries and should be reused. Digital-asset wallets add further requirements.

Coldcard, as an evaluation lesson rather than as a news item. On specific firmware, a weak software generator was used, so partial output is easier to predict than output of a true generator. Wallets were drained. The end-user assumption is that a hardware wallet is secure, including while it is powered off and disconnected. If the seed can be guessed, offline and powered off is not a defense.

Two narrower lessons: open source of part of the implementation does not mean the bug will be found. A secure chip inside the device does not make the device secure. Security depends on how the rest of the wallet uses the chip.

Frameworks that already exist. A survey over the preceding months, shown at GDC:

Smart-card and secure-element evaluation. Banking cards and identity chips have a long Common Criteria practice. Expected robustness is understood. Exploits happen, and the notify-and-fix path is mature. Those profiles are not specific to a digital-asset wallet, and some wallet functions are absent.

FIDO Alliance requirements for authenticators, FIDO2 and UAF (captions: "502" and "Uaf"). Authentication, not custody of assets.

GlobalPlatform TEE components and TEE protection profiles. Specific to the TEE.

EU digital-identity wallets, mentioned in Geneva to interest that community, and not developed in this session.

The HSM market as driven by PCI, and FIPS 140-3 for cryptographic modules.

The one certification path already applied to digital-asset hardware wallets: Ledger's French CSPN evaluations. CSPN was described as a lightweight Common Criteria-style process, French in origin and now aligned with a European lightweight scheme, with a fixed number of evaluation days. The security target was defined with the French cybersecurity agency, ANSSI (captions: "SSI"). The first certification was in 2019. Later devices followed. The newest devices may not all be covered. Relative to this BGIN work, 2019 was early.

An official evaluation has one useful side effect. Certification publication requires a security target to be disclosed. It is a light description, not the full design, and it states the goal and what was checked.

Functions visible in those Ledger security targets, the earliest of which was described as the most complete:

A random-number generator, so key generation has a stated entropy source.

Attestation, in particular that the wallet is using its secure chip and that this can be checked.

End-user verification when a transaction is authorized. In practice, a PIN, as in banking.

A secure update over a secure channel.

Application isolation. A multi-chain wallet holds different keys and sometimes different seeds. An application for one chain must not be able to use another chain's keys. Isolation matters more where third-party applications can be loaded, because a third-party application is then in a position to attack the others.

Signature-creation profiles are related and not enough. Qualified signature-creation devices, including under eIDAS in Europe, already try to secure the act of creating a signature. Signing a transaction is that act. The differences: those protection profiles assume conventional signature cryptography, which is not true of every chain, and they do not necessarily cover seed generation or key recovery. Part of the wallet problem is inside them. Enough of it is outside that they cannot be adopted unchanged.

HSM and secure-element vendors were the reason to start from these frameworks. A protection profile that ignores existing certifications forces a full new evaluation. The cost case for an add-on to a certification the vendor already holds was made explicitly. A from-scratch profile was described as a reason vendors will not come.

The supply-chain attack that the certification did not cover. A recent hardware-wallet compromise, on Ledger devices, was described as outside the certification they had passed. What was certified was not what failed. The scope was too narrow for what a hardware wallet actually does.

The certified story, as read from the public security targets, covered use of the secure chip, user verification, software update, and application isolation. It did not cover the path from the chip to the display that shows the holder what is happening. That path is what was attacked.

As summarized in the room: some devices were opened. Wires between the secure element and the display, or the microcontroller that drives the display, were tapped. An extra component, described as a SIM card, was inserted. During onboarding, the seed phrase is sent from the secure element to the

display. The seed words — a 24-word phrase — were captured on that path and exfiltrated. A secure chip does not help if the interface to the outside of the chip is not in the evaluation.

Public reporting named one reseller. The submitted supply-chain introduction (slide 7) identifies it as CryptoBilis; this resolves the caption "Crypto Billies" as a reported reseller name. Modified devices were also identified at a reseller in Germany. The incident was very recent. Full detail was not claimed. The activity may have been prepared over many weeks. Devices were sold into the market. On the order of 300 victim wallets had been identified. The attackers waited to drain until assets were present. Before that, smart contracts used to move the assets quickly had been tested, so the drain itself was rehearsed. The campaign was described as planned.

The same modification was cited in the offline-key session as a way a cold device becomes effectively online. The technical account is this one.

Three profiles, not one, and assurance that scales with systemic risk. The work as scoped in the room:

Which use cases: which wallets, which chains, which signing flows, one user or many.

Map those to threat models. That mapping is where a digital-asset profile diverges from a generic cryptographic device.

Targets of evaluation at least include a hardware wallet, a pure software wallet, a TEE-based wallet, and an HSM-based wallet.

The working hypothesis is three protection profiles. One for non-custodial, self-managed wallets. One for custodial, HSM-backed wallets. One for MPC or threshold-signature wallets, because one HSM in one system is a different threat from shares on servers in different places. This was not a decision to draft all three, or any one of them, first.

Assurance levels are open. Billions under custody and one person's balance are not the same risk, with the caveat that some individuals hold institutional-scale value. The banking analogy: breaking one smart card can be cheap. The problem is an attack that reproduces across the installed base and becomes systemic. A low assurance level can be honest for a single user and too low for a product in wide use.

Threats named by level, still as a sketch:

Basic: phishing, malware, weak random-number generation.

Substantial: remote attack, supply chain, key extraction.

High: physical attack, side channels, insiders. An insider here includes someone who can trap an HSM before it is deployed, or who can circumvent controls alone.

The brainstorm list of threats:

Random-number generation.

Key storage.

Isolation of applications or processes.

Supply chain, firmware and hardware. The recent attack was cited as evidence that hardware supply chain is no longer optional.

Remote exploitation.

Missing user authentication.

The update path. A bad firmware update is a persistent compromise.

Side channels, including power analysis.

Attestation, from the smallest secure component out through the software chain.

The cryptographic primitives themselves.

Post-quantum migration: the product has to be able to move to a new algorithm.

For MPC specifically: confidentiality of node-to-node communication, and collusion among the threshold.

What identity-wallet profiles share, and what they miss. Some capabilities match digital-identity wallets. Some do not. Seed-phrase confirmation is in the missing set, and it is exactly what the display-tap attack exploited. It is absent from older schemes because those schemes are not about digital-asset seeds.

Blind signing is only partly covered. The requirement is that the holder signs the transaction they think they are signing. Signature-creation profiles have some of this. For an HSM-backed flow the signature is produced in the back end, so the requirement becomes: consent is captured on the client, the back end signs that statement, and the client receives proof that the signed bytes are the consented bytes. That pattern was offered as something to copy, not as a finished requirement.

Post-quantum agility was acknowledged and not re-argued. The previous day had covered it. Leaving migration capability out of the first version of a profile was called a mistake because of the timeline.

Reference designs. Usual practice when writing a protection profile: define a reference architecture so the chain from threat, to requirement, to evaluation activity can be tried end to end. The same designs become developer guidance. They need not mandate one control. They can say which controls are known to meet a requirement. Other industries have done this repeatedly.

Who has to be in the room before a profile is real. Vendors, representatives of end users, and the security agencies that would issue a certificate. A requirement set those agencies do not recognize will not be certified. A requirement vendors cannot implement will not be shipped. The near-term output can still be guidance and assessment aids for products that exist now.

The Ledger case was used to bound expectations. A security target will not cover every future attack. It reduces risk by forcing threats to be named, controls to be mapped, and conformance to be checkable. Attacker capability changes, so the profile has to be revisited. The maturity claim was modest: an industry that goes through the process gets progressively harder to ship a trivially weak product into.

Certification might become mandatory for wallet providers. Not soon. The reason to draft now is so that a mandate is not the first time the requirements exist.

How far along, and the European identity-wallet schemes. A participant who wants to work on this asked whether the effort is early or somewhat advanced, and how to join. BGIN was identified as the forum that should be doing it.

In Europe, ENISA was described as starting certification schemes for digital-identity wallets. The captions say "Anissa" and "security relation schemes." Full convergence of an asset-wallet scheme and an identity-wallet scheme was not claimed. Reuse of the overlapping part was the ask, even while the overlap is incomplete. One profile will not cover both worlds now. It might later. If the common functions are evaluated the same way, a vendor who already holds one certificate finishes an add-on instead of starting over. That was called the point of convergence. The offer to include the additional participant was accepted.

Weakness enumeration and prior art. The discussion considered hardware-security weakness enumeration:

CWE has a hardware section. Hardware vendors are involved. GlobalPlatform is not in that effort yet. Intel is. NVIDIA also appears in MITRE's published hardware-weakness contributors; this supports the caption correction.

Side channels are CWE-1300.

A 2019 Trezor wallet issue has a CVE. The point made in the room: the failure mode was already described, and it happened again anyway.

Work related to the EU Cyber Resilience Act, and to open programmable-logic-controller security standards, has put CWE references into regulatory text so that listed weaknesses are in the build requirement. This was offered as a CWE success story, with an explicit caveat that it might be the wrong instrument for wallets.

The MIT Digital Currency Initiative's OpenCBDC implementation included an open wallet and a user interface. A finding from that work: the value in the wallet is visible. There is no zero-knowledge protection of the balance. Privacy of the amount was flagged as its own problem. The aside that retail CBDC deployment in the United States has stopped was context, not a wallet requirement.

Known nonsense failures — a weak or misused generator, a display path that can be tapped — are already in the public record. The Trezor case and the new display-tap case were called the same history.

The reply: guidance and a weakness list are not the goal. A security target and a protection profile are a way to push, eventually, for mandatory certification. If the control stays optional, the same incidents continue. That is the practical failure mode of publishing CVEs. Most digital-asset wallet teams are small. They will not absorb the whole history of smart-card attacks. The illustration from about ten years ago: some hardware-wallet efforts (a name rendered "Twizzers" is [unverified]) treated a secure element as proof the wallet was secure. Others treated a microcontroller the same way. The component is not the product.

Hot versus cold was accepted as another axis a profile might use, alongside the three-way split already proposed.

Wallets held for an agent, and portability. Two further issues were named and not taken into the threat baseline:

Zero-knowledge hiding of the balance, from the OpenCBDC observation.

Agents initiating transactions, including trivial recurring purchases. The wallet those agents use may sit in someone else's custody. The holder authenticates with a password to a wallet operated for them, and someone else can act. The control question is who is authorizing whom. One stated advantage of a custodial wallet is that a forgotten password is recoverable. The counter from the decentralized-identity side: credentials are portable and can be reissued. A driver's license still comes from the motor-vehicle agency if a wallet is lost. Moving credentials between wallets is part of that specification. Interoperability was the property cited. This was a pointer back to the privacy session's framework, not a new requirement.

Status of the BGIN activity itself. The security-target work started about a year before this block. The first six months were quiet. The last few months have had more discussion. The judgment in the room: not far from a draft. Threats are identified. Security requirements are at baseline. The missing decision is whether to cover every wallet class or to start with one. That choice follows whoever shows up. HSM vendors would be a reason to start with an HSM profile. Gemalto was named as another HSM and smart-card manufacturer, in the Netherlands, and as now part of Thales. The set of HSM vendors is small.

Protocols between wallets, not only the device. A flaw in card-brand cryptography was cited from traditional payments. A paper identified editorially as the USENIX Security 2021 card-brand mix-up study described presenting a Mastercard as a Visa. The transaction still cleared. The flaw was in the protocol among the terminal, the processor, and the card: checking could be downgraded and then bypassed. The network whose rails were used bore the loss. Who would choose to run that attack was left open. The wallet analogy: a profile that ignores the protocol between wallets, and between a wallet and the chain, is incomplete. How many such protocols exist is unknown. Passing one chain's asset off as another's, in a multi-asset wallet, is the same shape of bug. Partition of keys per asset type is the practical question.

A second remembered case, not nailed to a paper: on an Ethereum layer-2, a transaction could be made to look like a harmless signature, or like a transfer on a different layer, while a token moved on the layer the user did not see. The room treated this as the same interface-confusion class, already known, and typically untested. It was called out as in scope for a protocol profile and was not specified further.

The session was then closed. Remote participants were asked for comments and none were taken. Slides were offered by email. Joining the BGIN discussion forum was mentioned.

After the close. A MITRE protocol tool, CPSA, the Cryptographic Protocol Shapes Analyzer, was described as published and usable beyond its original government audience. It does not model every protocol. From a model it enumerates the shapes of the protocol. The analogy offered was Amazon's use of TLA+ to model isolation of an ordering process so that concurrent orders do not race. Anyone

can use that class of tool. This was a hallway pointer toward protocol analysis. It was not a decision to use CPSA on a wallet profile.

Matters not resolved

Institutional custodian wallets, end-user wallets, or both, as the first target of evaluation.

One protection profile or three: non-custodial, HSM custodial, and MPC or threshold. Hot versus cold was accepted as a further axis and not assigned to a draft.

Which assurance level attaches to which product. Per-user risk and systemic reproducibility were both treated as real, and no level was chosen.

Whether certification should become mandatory. The argument for a profile was that optional guidance has not stopped repeated failures. A participant presented CWE-in-regulation as a success and declined to say it is the right tool here. No mandate was proposed as a BGIN position.

How far to converge with ENISA's digital-identity wallet schemes. Reuse the overlap. Do not pretend one profile covers both worlds today.

Whether privacy of the balance, by a zero-knowledge proof, is a wallet security requirement or a separate privacy requirement. Raised from OpenCBDC. Not added to the threat list in the session.

Whether agent-operated wallets and custodial password recovery belong in this profile or in the identity and agent work.

Whether chain and token mix-up, and layer-2 interface confusion, are threats in the first profile or a later protocol profile. The room said they are real and usually untested.

Which vendor community will actually draft. HSM vendors pull toward an HSM profile. The drafting scope remains open pending wider vendor engagement.

Post-quantum migration is in scope. The technical content was explicitly deferred to the previous day's discussion.

CPSA as a tool for this work. Mentioned after the close. Not adopted.

Disposition of the work

The security-target activity is about a year old. Six quiet months, then a more active few months, including the Geneva GDC presentation in early September. A report of that presentation is on the BGIN website. This block received no contributed papers.

Threat identification is far enough along to call a baseline. Security requirements are not written as a profile. Three candidate profiles and a hot/cold axis are a hypothesis. Assurance levels are unset. Reference architectures are an intended method, not a document.

Vendor participation is the gap the room was most explicit about. Gemalto was noted as part of Thales. GlobalPlatform contacts exist and have not produced a joint text. The public CSPN security targets remain the main concrete artifact from a vendor evaluation, and they are inputs, not BGIN text.

ENISA's work on digital-identity wallet certification schemes is parallel. It is not a BGIN deliverable.

Convergence means reuse of common requirements.

No protection profile was started in the session. The closing judgment was that a draft is not far off once a first wallet class is chosen.

Actions

Each action is written so that it can be tracked without the rest of the record. Where the room named only a person, the action is kept and the name is omitted.

Decide the first use case and assurance level, then start one protection profile rather than boiling every wallet class at once. If HSM vendors engage, an HSM-backed custodial profile is the likely start. If they do not, the choice stays open.

Turn the threat list into security requirements, at least one per threat, and mark what is already covered by an existing profile versus what is digital-asset-specific. Seed confirmation, display binding, hardware supply chain, and blind signing are the gaps already named.

Draft a short position paper or statement whose audience is HSM vendors, wallet vendors, integrators, and custodians. The absence of those people was the reason this session had no external papers.

Keep the European identity-wallet schemes in view so shared functions are not specified twice. Do not block on a single joint scheme.

Use CWE hardware weaknesses, including CWE-1300, and the existing wallet CVEs as source material for the threat list. This is an input, not a decision to put CWE identifiers into a regulation.

Include protocol confusion — chain mix-up, layer-2 interface confusion — when the profile's boundary is drawn. It was not specified here.

Revisit post-quantum migration inside the profile using the previous day's substance, so agility is not bolted on later.

The CPSA suggestion arrived after the close. It is a candidate tool for protocol shapes, not a work item until someone picks it up.

Slides were to be shared by email. Discussion continues on the BGIN forum. Working-group meetings over the coming weeks and months are where the use-case choice and the requirement text are supposed to move.

Coverage

This record covers the published ST/PP session in Room B at 16:10–17:40. The recording continues to the end of the file, including informal technical discussion after the formal close. Figures are reported session claims, not independently validated measurements. Technical names are corrected where supported by the recording, chat, or identified primary documentation. Where a name could not be checked against another part of the same recording, it is left unverified rather than guessed. Logistics, introductions, and names of speakers are omitted.

The opening of the slice is pre-session talk: time zones, unread white papers, a joke about an agent in orbit rotating keys, and a note that some inputs had been sent and not discussed. That note was not

tied to a security-target document. It is not recorded above as a contribution.

Housekeeping omitted: mute checks, who was online, and the exchange of email addresses after the close. Personal names are omitted.

The session did reach a spoken close. The supply-chain attack, the three-profile hypothesis, the threat list, the certification-scope lesson, and the vendor gap were all in the session proper. The CPSA and TLA+ exchange was after the close and is marked that way so it is not read as a decision to adopt a tool.

Source clarifications and open checks

"ECM keys" for one chain's keys beside Bitcoin keys.

"Twizzers" for an early hardware-wallet team.

CryptoBilis is the reseller name in the submitted supply-chain introduction, slide 7 (`https://bgin-global.org/documents/block-events/block15/CS/Block15_Supply_Chain_Intro.pdf`). This identifies the reference without independently establishing the incident allegations.